

Aspectos éticos, sociales y profesionales avanzados y la Seguridad de la Información

Módulo 3: parte Seguridad y Privacidad de la Información
Clase 1 · Actualización 2026

Docentes: Javier Diaz y Soledad Gomez

Seguridad de la información

- ¿Qué se debe asegurar?

La información: La nuestra y la de la organización donde trabajamos.

- ¿Cuál es el lugar que ocupa la información?

La información constituye un **activo muy importante para la organización**, ya que tiene un rol fundamental a la hora de cumplir sus objetivos.

Debemos proteger la información adecuadamente garantizando su seguridad y privacidad.

Seguridad de la información

Definamos más formalmente:

- **ACTIVO:** un activo de TI es hardware, sistemas de software o información que tienen valor para una organización
- **VULNERABILIDAD:** Es una **DEBILIDAD** en un activo
- **AMENAZA:** Es el problema que potencialmente puede ocurrir si se **aprovecha una debilidad/vulnerabilidad**.
- **INCIDENTE:** Se produce cuando **la amenaza se concreta** y atenta contra la seguridad de la información.

Principios básicos de seguridad: tríada CIA

Confidencialidad

La información solo debe ser accesible por personas, sistemas o procesos autorizados.

Integridad

La información debe mantenerse exacta, completa y protegida frente a modificaciones no autorizadas.

Disponibilidad

Los usuarios autorizados deben poder acceder a la información y a los servicios cuando los necesitan.

Ejemplo: banca online → datos cifrados (C), registros contables no alterados (I), plataforma operativa (D).

Ciberincidente según NIST

Un incidente es un suceso que pone en peligro real o inminentemente la confidencialidad, integridad o disponibilidad de la información o de un sistema de información.

También puede ser un suceso que viola políticas de seguridad, procedimientos de seguridad o niveles de riesgo aceptable.

La definición permite vincular el incidente con los tres atributos básicos de la seguridad: confidencialidad, integridad y disponibilidad.

NIST: National Institute of Standards and Technology, referencia internacional en materia de ciberseguridad.

Historia de la Ciberseguridad

- Década 1960–70: seguridad centrada en acceso físico y control de usuarios en mainframes.
- Década 1980–90: primeras redes y virus → aparición de antivirus y firewalls.
 - 1995 surge Internet comercial
- Década 2000–10: cibercrimen organizado, botnets, ataques DDoS y auge del comercio electrónico.
- Década 2010–20: amenazas avanzadas persistentes (APT), ransomware global, seguridad en cloud e IoT.

Historia de la Ciberseguridad

- 2020 en adelante:
 - Explotación de vulnerabilidades como servicio (VaaS) → venta y alquiler de exploits y kits de ransomware.
 - Hacktivismo como actor global (Anonymous, ataques vinculados a conflictos geopolíticos como Rusia–Ucrania).
 - Grandes corporaciones de hackers y ransomware gangs (ej. Conti, REvil, LockBit) operando como empresas con estructura, servicio al cliente y programas de afiliados.
 - Crecimiento del mercado negro digital en dark web y profesionalización del cibercrimen.
 - Tendencias actuales: IA en ciberataques, ataques a la cadena de suministro (ej. SolarWinds), guerra cibernética y ciberespionaje estatal.

¿Cómo cambia la IA la Ciberseguridad?

La IA generativa dejó de ser una herramienta experimental: ya forma parte del estudio, el trabajo y la gestión.

Para las instituciones educativas, el desafío pasó de “prohibir” a gobernar su uso: políticas, privacidad, evaluación, seguridad y trazabilidad.

Aumentan los riesgos de Shadow AI: uso de herramientas no aprobadas que pueden exponer datos personales, información institucional o propiedad intelectual.

La seguridad y la privacidad deben pensarse juntas: proteger sistemas, datos, identidades y decisiones automatizadas.

Incidente clásico vs. incidente de IA

Ciberincidente clásico (NIST)

Suceso que pone en peligro real o inminente la **confidencialidad**, integridad o **disponibilidad de información o sistemas**, o viola **políticas de seguridad/uso aceptable**.

Se analiza con indicadores de compromiso: red, endpoint, identidad y aplicaciones.

Incidente de IA / GenAI

Evento donde un sistema de IA genera resultados dañinos no previstos, eleva el riesgo o es manipulado para producir impactos técnicos, sociales, éticos o institucionales.

Puede existir sin atacante —por ejemplo, alucinaciones— o por manipulación.

Incluye daños de ciberseguridad, privacidad, desinformación o decisiones discriminatorias.

La IA puede producir daño incluso sin atacante: alucinaciones, sesgos, respuestas inseguras o acciones automatizadas incorrectas.

La investigación requiere trazabilidad de prompts, modelos, versiones, datos, conectores y acciones ejecutadas.

Criptografía: conceptos esenciales para seguridad y privacidad

Qué protege

Confidencialidad: que solo accedan quienes están autorizados.

Integridad: detectar modificaciones no autorizadas.

Autenticidad: verificar identidad u origen.

No repudio: vincular una acción o firma con una entidad.

Cómo enseñarla sin perder foco

No presentar algoritmos como catálogo aislado.

Explicar método → uso → riesgo → buena práctica → herramienta.

Conectar con HTTPS, VPN, firma digital, MFA, passkeys, mensajería y backups.

Idea clave: la criptografía falla más por mala implementación o mala gestión de claves que por la matemática.

Mapa de métodos criptográficos

Métodos principales

Cifrado simétrico: una clave compartida; rápido; datos en reposo y grandes volúmenes.

Cifrado asimétrico: par pública/privada; intercambio de claves, autenticación y firma.

Hash criptográfico: huella; integridad; no cifra ni permite recuperar el dato.

Firma digital: integridad + autenticidad + no repudio.

Uso combinado en la práctica

TLS/HTTPS combina asimétrica para negociar y simétrica para el canal.

PGP/GPG combina clave pública para compartir secreto y simétrica para cifrar contenido.

MFA y passkeys usan criptografía para verificar identidad.

PETs avanzadas permiten análisis sin exponer datos personales.

Cifrado simétrico: proteger datos con una clave compartida

Concepto y usos

Una misma clave cifra y descifra.

Muy eficiente para discos, bases de datos, backups, archivos y comunicaciones ya negociadas.

Algoritmo recomendado: AES con claves de 128/192/256 bits; preferir modos autenticados como GCM.

Evitar: DES, 3DES y configuraciones caseras.

Estrategias y herramientas

Gestionar claves separadas por uso y ambiente; rotación según riesgo.

Herramientas: BitLocker/FileVault/LUKS para disco; VeraCrypt para contenedores; OpenSSL o libsodium para desarrollo.

En nube: KMS/HSM del proveedor; Vault cuando hay gestión centralizada.

No guardar claves junto al dato cifrado.

Cifrado asimétrico: clave pública y clave privada

Concepto y usos

La clave pública puede compartirse; la privada debe protegerse.

Usos: intercambio de claves, firma digital, certificados, SSH, S/MIME, PGP/GPG y TLS.

Algoritmos usuales: RSA y curvas elípticas (ECC).

Es más lento que el simétrico, por eso suele combinarse con AES u otro cifrado simétrico.

Estrategias y herramientas

Proteger claves privadas con contraseña fuerte, hardware token, TPM o HSM según criticidad.

Herramientas: OpenSSL, GnuPG, OpenSSH, Age, YubiKey/PIV, HSM/KMS institucional.

Revisar vencimiento de certificados y cadena de confianza.

No compartir claves privadas por correo o repositorios.

Hash criptográfico: integridad, no confidencialidad

Concepto y usos

Transforma datos en una huella de longitud fija.

Permite verificar integridad de archivos, descargas, logs y evidencias.

No sirve para ocultar información: un hash no es cifrado.

Recomendados: SHA-256/SHA-384/SHA-512 o SHA-3. Evitar MD5 y SHA-1.

Estrategias y herramientas

Publicar hashes oficiales junto con software o documentos descargables.

Usar HMAC cuando se requiere integridad con clave compartida.

Herramientas: sha256sum, PowerShell Get-FileHash, OpenSSL dgst, GnuPG para firmas.

Para evidencias: registrar hash, fecha, responsable y cadena de custodia.

Contraseñas: no se cifran, se almacenan con hash robusto

Error frecuente: guardar contraseñas “cifradas” o en texto claro. La práctica correcta es hash de contraseña con sal única y costo computacional.

Algoritmos recomendados para contraseñas: Argon2id, bcrypt, scrypt o PBKDF2 bien parametrizado.

Estrategia: longitud mínima razonable, bloqueo ante ataques automatizados, detección de credenciales filtradas y MFA.

Herramientas: gestores de contraseñas como Bitwarden, KeePassXC o 1Password; Have I Been Pwned para exposición de credenciales; políticas NIST SP 800-63B.

Firma digital, certificados y PKI

Qué aporta

Integridad: detecta cambios sobre el documento.

Autenticidad: vincula la firma con un certificado o identidad.

No repudio: reduce la posibilidad de negar la autoría.

PKI: autoridades certificadoras, certificados, revocación y cadena de confianza.

Estrategias y herramientas

Usar certificados emitidos por autoridades confiables y con ciclo de vida controlado.

Herramientas: Adobe/LibreOffice para firmar PDF; OpenSSL; GnuPG; ACME/Let's Encrypt para TLS.

Verificar revocación, vencimiento y nombre del certificado.

Para trámites: separar firma, autenticación y autorización.

TLS/HTTPS: criptografía aplicada a la navegación

TLS protege la comunicación entre cliente y servidor: confidencialidad, integridad y autenticación del sitio.

Combina criptografía asimétrica, certificados digitales y cifrado simétrico de sesión.

Estrategias: usar TLS 1.2/1.3, certificados válidos, HSTS, configuración segura y eliminación de protocolos/cifrados obsoletos.

Herramientas: Let's Encrypt/ACME para emisión y renovación; SSL Labs Server Test para evaluar configuración; Mozilla SSL Configuration Generator.

Riesgo frecuente: HTTPS no garantiza que el sitio sea legítimo; solo indica un canal cifrado con un dominio certificado.

VPN y cifrado extremo a extremo

VPN

Crea un túnel seguro sobre redes no confiables.

Usos: acceso remoto institucional, administración segura, redes públicas.

Herramientas: WireGuard, OpenVPN, IPsec/IKEv2.

Buenas prácticas: MFA, perfiles por rol, logs y revocación de accesos.

Cifrado extremo a extremo

Solo extremos autorizados pueden leer el contenido.

Usos: mensajería segura, intercambio de archivos y correo con PGP/S/MIME.

Herramientas: Signal, WhatsApp E2EE, GnuPG, Age.

Cuidado: metadatos, backups y dispositivos comprometidos pueden exponer información.

MFA, OTP y autenticación adaptativa

Métodos

MFA combina factores: algo que sé, tengo o soy.

TOTP: código basado en tiempo; HOTP: basado en contador.

Push MFA: cómodo, pero expuesto a fatiga de aprobación.

SMS: mejor que contraseña sola, pero menos robusto.

Estrategias y herramientas

Priorizar cuentas críticas, administradores, correo, VPN, SSO y recuperación de cuenta.

Herramientas: Microsoft/Google Authenticator, Aegis, Duo, tokens hardware.

Mitigar MFA fatigue con number matching y alertas.

Monitorear accesos imposibles, nuevos dispositivos y cambios de método.

FIDO2, U2F y passkeys: MFA resistente al phishing

Cómo funciona

Usa criptografía de clave pública: el servicio guarda la clave pública; la privada queda en el dispositivo o llave.

La autenticación se vincula al dominio legítimo, dificultando phishing y credential stuffing.

Puede usarse con biometría local, PIN, llave física o autenticador de plataforma.

No se comparte una contraseña reutilizable.

Estrategia institucional

Comenzar por autoridades, administradores, SSO/IdP, correo, repositorios y finanzas.

Herramientas: YubiKey, Titan Security Key, Windows Hello, Touch ID, Android/iOS passkeys.

Definir recuperación de cuenta segura y enrolamiento supervisado.

Revisar riesgos de passkeys sincronizadas y dependencia del proveedor.

Gestión de claves: el punto crítico

La seguridad criptográfica depende de generación, almacenamiento, distribución, uso, rotación, revocación y destrucción de claves.

Separar claves por propósito: cifrado de datos, firma, autenticación, backups, ambientes y servicios.

Estrategias: mínimo privilegio, control de acceso, auditoría, rotación, doble control para claves críticas y protección contra exfiltración.

Herramientas: KMS de nube, HashiCorp Vault, HSM, TPM, SOPS, age, gestores de secretos de CI/CD.

Regla práctica: si la clave queda en un repositorio, chat, correo o planilla, el cifrado deja de proteger.

PETs criptográficas y privacidad

Técnicas

Anonimización y seudonimización reducen exposición, pero no siempre impiden reidentificación.

Cifrado homomórfico permite operar sobre datos cifrados.

Computación segura multipartita permite colaboración sin revelar datos individuales.

Differential privacy agrega ruido controlado para publicar estadísticas.

Cuándo usarlas

Investigación con datos sensibles o multiinstitucionales.

Analítica sobre datos de estudiantes, salud, movilidad o desempeño.

Compartir información minimizando datos personales.

Herramientas: OpenDP, PySyft, Microsoft SEAL, TF Encrypted, Decentriq y plataformas PET según caso.

Checklist: método, riesgo, estrategia y herramienta

Simétrica/AES → riesgo: clave expuesta → estrategia: KMS/HSM/Vault y separación de claves → herramientas: LUKS, BitLocker, FileVault, VeraCrypt, OpenSSL.

Asimétrica/RSA-ECC → riesgo: clave privada robada → estrategia: hardware token, TPM/HSM, passphrase → herramientas: OpenSSH, GnuPG, YubiKey, OpenSSL.

Hash/SHA-2/SHA-3 → riesgo: usar MD5/SHA-1 → estrategia: algoritmos vigentes y HMAC cuando corresponda → herramientas: sha256sum, Get-FileHash, OpenSSL.

TLS/HTTPS → riesgo: configuración obsoleta → estrategia: TLS 1.2/1.3 y renovación automática → herramientas: Let's Encrypt, SSL Labs, Mozilla SSL Config.

MFA/passkeys → riesgo: phishing y robo de sesión → estrategia: FIDO2/WebAuthn, monitoreo y recuperación segura → herramientas: passkeys, YubiKey, IdP/SSO.

Privacidad de la información

La privacidad de los datos es la protección de los datos personales frente a quienes no deberían tener acceso a los mismos, y la capacidad de los usuarios de determinar quién puede acceder a su información personal.

<https://es.wikipedia.org/wiki/Privacidad>

- La privacidad en Internet (privacidad digital o privacidad online) se refiere al control de la información que posee un determinado usuario que se conecta a la red. La privacidad puede implicar información de identificación personal o información no personal, como el comportamiento de un visitante en un sitio web.

https://es.wikipedia.org/wiki/Privacidad_en_Internet

¿Es lo mismo seguridad que privacidad?

- La privacidad se basa en controlar que la información o datos personales no queden expuestos para que cualquiera pueda verlos.
- Los servicios de Google tienen varias opciones relacionadas a la privacidad que podemos activar o desactivar:
 - Posibilidad de compartir nuestra ubicación en tiempo real
 - Valerse de nuestras preferencias de navegación para recomendarnos contenido
 - etc

Privacidad en Internet

La **privacidad** de los datos se centra en el uso y la gestión de los datos personales, cosas como la implementación de políticas para garantizar que la información personal de los consumidores se utilice.

Internet permite la interacción entre dos o más personas. Esto se ve reflejado en sitios como Facebook y Twitter, redes sociales donde se suelen compartir públicamente sentimientos, estados de ánimo, noticias, fotografías, videos, etc.

Si bien ésto forma parte de la interacción social normal, es necesario considerar que Internet es un “lugar” abierto al mundo, por lo que cualquier acción que se haga puede tener un impacto global y permanente.

¿Es lo mismo seguridad que privacidad?cookies

- +Almacenar o acceder a información en un dispositivo
- +Desarrollar y mejorar productos
- +Utilizar estudios de mercado a fin de generar información sobre el público
- +Medir el rendimiento de los anuncios
- +Seleccionar contenido personalizado
- +Crear un perfil para la personalización de contenidos
- +Seleccionar anuncios básicos
- +Seleccionar anuncios personalizados
- +Crear un perfil publicitario personalizado
- +Utilizar datos de localización geográfica precisa
- +Medir el rendimiento del contenido
- +Analizar activamente las características del dispositivo para su identificación

No solo cookies: art. 5.3 Directiva e-Privacy

Tecnologías de seguimiento y consentimiento

- URL y pixel tracking.
 - Un píxel de seguimiento: hipervínculo a un recurso, generalmente un archivo de imagen, incrustado en un fragmento de contenido, como una web o un email con el propósito de establecer una comunicación entre cliente y el host del píxel. La comunicación transmite información varia al titular del píxel.
 - Por su parte, los enlaces (URL) de seguimiento funcionan de manera similar pero el identificador va adjunto a la dirección web. Así, cuando el usuario visita el sitio web se carga, además del portal solicitado, un identificador, por ej. para rastrear el origen de una venta.
- Procesamiento en local.
 - Algunas tecnologías operan a través de la información producida por el procesamiento local, por ejemplo, en el caso de una API, a través de la que se puede acceder a los resultados de búsqueda del navegador.

No solo cookies: cont

Tecnologías de seguimiento y consentimiento

- Seguimiento basado en IP.
 - Si únicamente se utiliza la dirección IP del usuario para rastrear su actividad, ello estaría sujeto a la obtención del consentimiento siempre que dicha información se origine en el terminal de usuario.
- Informes de dispositivos IoT.
 - Los dispositivos IoT, cuando están conectados (directa o indirectamente) a una red pública de comunicaciones, se considerarían en sí mismos un equipo terminal. El hecho de que la información se transmita o almacene en caché para su notificación intermitente no cambia...
- Identificadores únicos.
 - Estos identificadores se recopilan y comparten entre varios responsables para identificar unívocamente a una persona. Aunque pueda ser el usuario el que introduzca la información

Privacidad y redes sociales

Existen muchas redes sociales

→ Uno de los principales problemas asociados a su uso es la mala configuración de la privacidad.

→ Esto determina que datos se exponen a qué personas.

Una mala configuración de privacidad puede exponer más de lo que pretendemos.



Privacidad y Ética en Google

Privacy Concerns: A Permanent Digital Footprint

“DeviceLink” proporciona integración y seguimiento en todos los dispositivos de los usuarios. Desde teléfonos y tabletas hasta dispositivos domésticos inteligentes y wearables, un único ecosistema. Seguimiento de ubicación constante, monitoreo de comportamiento: integración de datos entre dispositivos:

<https://vocal.media/education/breaking-news-google-s-new-tracking-tool-the-end-of-digital-privacy>

Datificación (Datafication)

Datificación es el proceso de transformación de sujetos, objetos y prácticas en datos digitales

Datificado: ser convertido en datos digitales o ser caracterizado o basarse en el análisis de datos. Se refiere al proceso de convertir diversos aspectos de la vida en datos cuantificables y analizables. Lo que impacta diversos aspectos de la sociedad, como la gobernanza, el trabajo, la salud y la educación.

<https://www.openglobalrights.org/what-a-datafied-worldview-means-for-human-rights/>

Hiperpersonalización y Ética

Hiperpersonalización: es un enfoque de marketing que utiliza tecnologías avanzadas como la IA y el aprendizaje automático para ofrecer experiencias altamente personalizadas e individualizadas a los clientes. Va más allá de la personalización tradicional al analizar datos en tiempo real y el comportamiento del cliente para crear interacciones únicas y específicas para cada individuo. Analisis predictivo.

- Los consumidores están dispuestos a compartir datos personales si reciben experiencias personalizadas, pero pocos confían plenamente en las empresas que gestionan sus datos.

Privacidad y Ética en Google

En febrero 2025 cambió sus Principios para la IA, eliminando la prohibición de desarrollo de armas, al igual que hizo OpenAI en enero 2024.

<https://www.xataka.com/robotica-e-ia/google-ha-actualizado-sus-principios-para-ia-ha-desaparecido-mencion-a-no-desarrollar-armas-esta-tecnologia>

Privacidad y Ética en Meta

El Modelo de Negocio de Meta

- **Definición:** Meta no solo es una red social; su modelo se basa en la **publicidad de vigilancia**.

<https://www.eff.org/deeplinks/2025/01/mad-meta-dont-let-them-collect-and-monetize-your-personal-data>

- **Recolección de Datos:** Meta recopila información personal a través de sus plataformas y también a través de millones de sitios web y aplicaciones externas.
- Un tercio de los sitios top 10.000 websites comparten con Meta

Privacidad y Ética en Meta cont.

- **Seguimiento Extensivo:** Meta monitoriza el comportamiento del usuario más allá de sus plataformas con píxeles de seguimiento etc
- **Recolección de Datos de No Usuarios:** Meta ha admitido recolectar información sobre personas que no tienen cuentas
- **Consentimiento Informado:** Los usuarios a menudo no son plenamente conscientes del alcance del seguimiento ni del uso que se da a sus datos.
- **Explotación Comercial:** La monetización de datos personales sin un consentimiento claro es una violación ética que debe ser abordada

Autos conectados: datos y privacidad

- Un auto moderno combina sensores, software, conectividad y servicios digitales.
- Puede registrar ubicación, rutas, velocidad, frenadas, diagnóstico, contactos sincronizados, llamadas y hábitos de conducción.
- Aporta seguridad vial, mantenimiento predictivo, asistencia al conductor y recuperación ante robos.
- También habilita perfilado, vigilancia, cesión a terceros, uso comercial e incidentes de ciberseguridad.
- Clave para la clase: quién controla los datos, con qué finalidad, por cuánto tiempo y con qué consentimiento.

Autos conectados: monitoreo y regulación

- Los sistemas de monitoreo del conductor pueden detectar fatiga, distracción, posición de cabeza, uso del celular o presencia de pasajeros.
- La finalidad declarada suele ser reducir accidentes, pero el monitoreo permanente exige minimización de datos, transparencia y límites de uso.
- Buenas prácticas: revisar permisos de la app/vehículo, evitar sincronizar datos innecesarios, actualizar software y borrar datos antes de vender o alquilar.
- Pregunta disparadora: ¿aceptamos más monitoreo si promete seguridad? ¿Qué controles deberían exigirse?

Información sensible y exposición en Internet

- Sitios, apps, redes sociales, nube y dispositivos conectados dejan rastros que pueden transformarse en información sensible.
- Ejemplos: ubicación, contactos, hábitos, imágenes, voz, datos académicos o laborales, credenciales, salud, finanzas y preferencias personales.
- Riesgos: suplantación de identidad, acoso, fraude, discriminación, ingeniería social, pérdida de reputación y uso no previsto de datos.
- Preguntas: ¿quién puede ver la información?, ¿dónde queda almacenada?, ¿se puede borrar?, ¿quién la reutiliza y con qué finalidad?

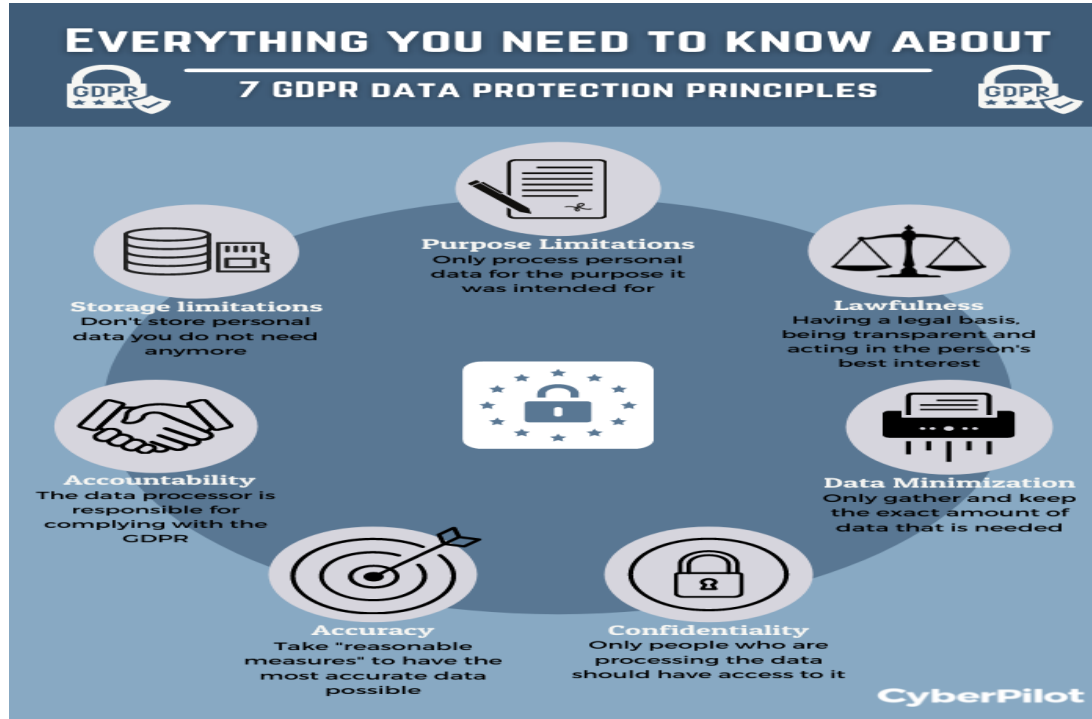
Legislación de Privacidad GDPR

Principios del RGPD

- Legalidad, Equidad y Transparencia;
- Limitación de propósito;
- Minimización de datos;
- Exactitud;
- limitaciones de almacenamiento;
- Integridad y Confidencialidad;
- Responsabilidad.

<https://www.cyberpilot.io/cyberpilot-blog/data-protection-principles-the-7-principles-of-gdpr-explained/>

Legislación de Privacidad GDPR



Legislación de Privacidad GDPR

How can I demonstrate that my organisation is compliant with the GDPR?

https://commission.europa.eu/law/law-topic/data-protection/reform/rules-business-and-organisations/obligations/how-can-i-demonstrate-my-organisation-compliant-gdpr_en

Software for GDPR compliance

Data Flow Mapping Tool

DPIA Tool (data protection impact assessment)

GDPR Manager

CyberComply

<https://www.itgovernance.co.uk/gdpr-compliance-software>

Privacy Enhancing Technologies

- Las tecnologías PET (Privacy Enhancing Technologies) son un conjunto de medidas técnicas diseñadas para proteger la privacidad de los datos personales.
- Permiten el uso de datos sin comprometer la privacidad, eliminando o reduciendo la información personal y evitando el procesamiento innecesario.
- Facilitan la explotación de datos que de otro modo no podrían utilizarse, cumpliendo con la legislación vigente y manteniendo la funcionalidad del sistema.

<https://www.decentriq.com/article/what-are-privacy-enhancing-technologies>

Relación entre Utilidad y Privacidad

- **Compromiso entre Utilidad y Privacidad:** A mayor protección de datos, menor utilidad; sin embargo, las tecnologías PET permiten alcanzar un equilibrio más favorable.
- **Técnicas PET Populares:**
 - **Anonimización:** Transformación de datos para que no se pueda identificar a individuos.
 - **Cifrado Homomórfico:** Permite realizar operaciones sobre datos cifrados sin descifrarlos.
 - **Computación Segura Multipartita:** Colaboración en cálculos sin revelar datos individuales.

Anonimización:

- Transformación de datos personales para que no sea posible identificar a individuos específicos
- Métodos comunes:
 - **Supresión:** Eliminación de identificadores directos (como nombres o números de identificación).
 - **Generalización:** Agrupación de datos en categorías amplias (por ejemplo, edades en rangos).
- Ejemplo: Compartir datos de pacientes eliminando nombres, pero conservando rangos de edad y síntomas para análisis epidemiológico.

Cifrado Homomórfico

Permite realizar cálculos directamente sobre datos cifrados, generando resultados cifrados que pueden descifrarse más tarde.

- **Características principales:**

- **Operaciones permitidas:** Suma, multiplicación y combinaciones complejas sin necesidad de descifrar los datos.
- **Clave privada:** Solo el propietario de los datos puede descifrar los resultados.

- **Ventajas:**

- Protege los datos durante todo el procesamiento.
- Ideal para análisis en entornos no confiables (como servicios en la nube).

- **Ejemplo:** Realizar cálculos estadísticos sobre datos financieros cifrados sin exponer detalles sensibles.

Computación Segura Multipartita (sMPC)

La sMPC es un protocolo criptográfico que permite a múltiples partes calcular conjuntamente una función sobre sus entradas, manteniendo la privacidad de esos datos.

- **Cómo funciona:**

- Los datos de cada parte se dividen en fragmentos cifrados.
- Los cálculos se realizan sobre los fragmentos distribuidos, y los resultados se combinan sin exponer los datos originales.

- **Ventajas:**

- Asegura la privacidad incluso en colaboraciones entre organizaciones con datos sensibles.
- Reduce el riesgo de fuga de datos.

- **Ejemplo:** Bancos colaboran para detectar fraudes analizando patrones de transacciones, pero sin compartir las cuentas de sus clientes.

Identidad Digital

Es el conjunto de datos, registros, credenciales, publicaciones e interacciones que representan a una persona u organización en el mundo digital.

Se construye con lo que compartimos, con lo que otros publican sobre nosotros y con las huellas que dejan nuestras actividades en Internet.

Suplantación de identidad digital

Como definición de suplantación de identidad podríamos decir que:

“La suplantación de identidad consiste en hacerse pasar por otra persona para obtener un beneficio.”

Con la aparición de la noción de identidad digital, análogamente apareció la problemática de la suplantación de identidad digital.

Es decir, la problemática existente en el mundo real se ve trasladada al mundo digital.

Si bien ha habido proyectos de ley para tipificar y considerar los casos de suplantación de identidad digital como delito penal en nuestro país, aún no es un delito contemplado en el Código Penal argentino.

Suplantación de identidad digital

Podemos decir que la suplantación de identidad en Internet puede hacerse de dos maneras:

- Accediendo ilegalmente a los perfiles de la víctima: En esta forma el delincuente debe conseguir la clave de acceso correspondiente a la víctima, por algún medio.
- Creando un perfil nuevo falso incluyendo información total o parcial de la víctima: Es mucho más sencillo que el primero, el delincuente solo tiene que escoger la víctima, recopilar su información y crear el perfil.

Seguridad de la información: amenazas

Objetivo del bloque: reconocer amenazas frecuentes, vincularlas con activos, vulnerabilidades, impacto e incidentes.

Eje de lectura: ¿qué atributo CIA afecta? confidencialidad, integridad, disponibilidad o más de uno.

Amenazas base: ingeniería social, phishing/BEC, malware, ransomware, botnets, DDoS, cadena de suministro, insider y fuga de datos.

Amenazas 2026: deepfakes, abuso de IA generativa, prompt injection, Shadow AI y agentes autónomos con permisos excesivos.

Mensaje central: la seguridad es un proceso socio-técnico; combina tecnología, personas, gobierno y respuesta.

De amenaza a incidente: cómo leer un caso

Cadena conceptual

Activo: información, servicio, identidad, equipo, datos personales o reputación.

Vulnerabilidad: debilidad técnica, organizacional o humana.

Amenaza: actor o situación que puede explotar la debilidad.

Incidente: la amenaza se concreta o está por concretarse.

Preguntas guía

¿Qué activo se compromete?

¿Qué atributo CIA se afecta?

¿Hubo acceso indebido, alteración, interrupción o exposición?

¿Qué evidencia permite responder y aprender?

Panorama 2026: amenazas más relevantes

Ingeniería social sigue siendo el principal punto de entrada: phishing, vishing, smishing, malspam y malvertising.

Ransomware combina cifrado, robo de datos, extorsión pública y presión regulatoria.

DDoS y amenazas contra disponibilidad siguen siendo críticas para servicios públicos y plataformas educativas.

Explotación de vulnerabilidades y ataques a cadena de suministro afectan software, bibliotecas, proveedores y servicios cloud.

La IA amplifica velocidad, personalización y escala de ataques; también mejora detección, análisis y respuesta.

Ingeniería social: el ataque apunta a la decisión humana

Busca manipular confianza, urgencia, miedo, autoridad, curiosidad o reciprocidad.

Canales: correo, llamadas, mensajería, redes sociales, QR, reuniones virtuales y soporte falso.

Ejemplos: pedido urgente de transferencia, supuesto soporte técnico, cambio de cuenta bancaria de proveedor, falso directivo.

Controles: verificación fuera de banda, doble aprobación, cultura anti-urgencia, canales oficiales y capacitación con simulacros.

Frase para clase: no es “culpa del usuario”; es un vector de ataque que debe mitigarse con procesos y diseño seguro.

Phishing, BEC, smishing y vishing

Qué buscan

Credenciales de correo, SSO, bancos o sistemas institucionales.

Transferencias o cambios de CBU/IBAN de proveedores.

Instalación de malware o autorización de MFA por cansancio.

Datos personales o información sensible.

Cómo reducir riesgo

MFA resistente al phishing y passkeys donde sea posible.

DMARC, DKIM y SPF para autenticidad del correo institucional.

Revisión de URLs, adjuntos y urgencias artificiales.

Call-back a números conocidos para pagos o cambios críticos.

Deepfakes: del engaño al fraude operativo

IA generativa permite voz, imagen y video falsos cada vez más convincentes.

Riesgos: fraude de pagos, suplantación de autoridades, manipulación reputacional, falsas entrevistas y vishing avanzado.

Caso de clase: videollamada con supuestos directivos que autoriza una transferencia urgente.

Mitigaciones: doble aprobación, palabra segura, verificación por canal alternativo, límites de monto y entrenamiento específico.

El control clave no es “detectar todos los deepfakes”, sino impedir que una sola interacción habilite una acción crítica.

Malware y ransomware: impacto en continuidad y datos

Qué hacen

Ejecutan acciones no autorizadas: robo, espionaje, cifrado, destrucción o control remoto.

Ransomware moderno: cifrado + exfiltración + extorsión + presión pública.

Puede afectar aulas virtuales, expedientes, sistemas administrativos, correo y repositorios.

Defensas esenciales

Parches, EDR/antimalware, segmentación y mínimo privilegio.

Backups inmutables y pruebas de restauración.

No ejecutar adjuntos o software no confiable.

Plan de respuesta: aislar, preservar evidencia, comunicar y recuperar.

Botnets y DDoS: amenaza contra disponibilidad

Botnet: red de equipos comprometidos controlados por un atacante mediante infraestructura de comando y control.

DDoS: múltiples orígenes saturan recursos de red, servidores, aplicaciones o servicios externos.

Técnicas: reflexión, amplificación, abuso de servicios expuestos y tráfico distribuido de IoT comprometido.

Impacto: indisponibilidad de servicios, degradación de trámites, clases, exámenes, gestión y atención a usuarios.

Mitigación: protección DDoS del proveedor, rate limiting, arquitectura resiliente, monitoreo, playbooks y pruebas.

Cadena de suministro y nube: confiar también es un riesgo

El atacante puede entrar por proveedores, bibliotecas, actualizaciones, integraciones, APIs, SaaS o cuentas cloud.

Riesgos típicos: credenciales expuestas, dependencias vulnerables, permisos excesivos, repositorios públicos y configuraciones por defecto.

Buenas prácticas: inventario de terceros, SBOM cuando aplique, revisión de accesos, contrato con requisitos de seguridad y monitoreo.

Para universidades: evaluar herramientas externas antes de subir datos personales, institucionales o resultados de investigación.

La seguridad contractual y la seguridad técnica deben dialogar: no basta con aceptar términos de uso.

Amenazas internas y errores: negligencia, abuso o accidente

No toda amenaza proviene de un atacante externo: también hay errores, accesos indebidos, fuga accidental o abuso de privilegios.

Ejemplos: compartir planillas con datos personales, permisos abiertos, credenciales reutilizadas, envío a destinatario equivocado.

Controles: mínimo privilegio, separación de funciones, registros de auditoría, revisión periódica de permisos y clasificación de información.

La prevención debe evitar culpabilizar: diseñar procesos que reduzcan errores y faciliten reportar incidentes temprano.

Privacidad y seguridad se cruzan cuando el incidente involucra datos personales o información sensible.

Shadow AI: uso no gobernado de IA

Shadow AI: uso de herramientas de IA no evaluadas o no aprobadas para tareas institucionales.

Riesgos: exposición de datos personales, información sensible, propiedad intelectual, evaluaciones, exámenes o documentos internos.

También puede producir decisiones opacas, sesgos, alucinaciones y pérdida de trazabilidad.

Respuesta institucional: inventario, criterios de uso, clasificación de datos, evaluación de proveedores y capacitación.

Regla simple para clase: no subir a herramientas externas aquello que no se debería publicar o compartir sin autorización.

Ataques a GenAI y agentes

Contra sistemas de IA

Prompt injection directa o indirecta.
Jailbreak y extracción de instrucciones.
Exfiltración desde RAG, conectores o memoria.
Data/model poisoning y abuso de herramientas.

Por agentes de IA

Automatización de reconocimiento y fraude.
Acciones a escala: correo, documentos, APIs o infraestructura.
Riesgo de permisos excesivos y falta de trazabilidad.
Necesidad de supervisión humana en acciones críticas.

Mitigaciones para GenAI y agentes

Separar contenido no confiable de instrucciones del sistema y de acciones privilegiadas.

Aplicar mínimo privilegio, allowlists de herramientas, sandboxing, rate limiting y dry-run.

Human-in-the-loop para pagos, publicaciones, cambios de infraestructura y acceso a datos sensibles.

RAG y memoria: controlar fuentes, ingestión, permisos, limpieza de contexto y posibles datos envenenados.

Auditoría: registrar prompts, tool-calls, decisiones, versiones de modelo, conectores y datos utilizados.

Respuesta a incidentes: antes, durante y después

Preparación y detección

Inventario de activos y datos críticos.
Backups probados, segmentación y MFA.
Monitoreo, logs, alertas y canales de reporte.
Playbooks para ransomware, phishing, fuga de datos y GenAI.

Contención y aprendizaje

Aislar sistemas afectados y preservar evidencia.
Comunicación institucional y legal coordinada.
Recuperación priorizada de servicios críticos.
Post-mortem: causas, controles y mejora continua.

Lecturas y fuentes recomendadas

NIST CSRC Glossary: definición de incidente y relación con confidencialidad, integridad y disponibilidad.

NIST SP 800-61r3: respuesta a incidentes integrada a la gestión de riesgos.

ENISA Threat Landscape 2025: panorama de amenazas, ransomware, DDoS, phishing y cadena de suministro.

OWASP Top 10 for LLM Applications 2025 y OWASP GenAI Incident Response Guide.

FIDO Alliance: passkeys y autenticación resistente al phishing.

MetaRED: materiales de ciberseguridad para instituciones de educación superior.